DEVSECOPS-SBOM-SECURITY-QUALITY

DevSecOps·SBOM과 보안 품질 자동화

연관 기출 · 135-2-2, 136-4-6, 131-1-13, 134-3-3

한눈에 이해

보안을 마지막 검사 한 번에 맡기지 않고 코드·의존성·빌드·배포·운영에 검증과 책임을 연결합니다.

정의와 핵심 원리

DevSecOps는 개발·보안·운영이 보안목표와 책임을 공유하고 CI/CD수명 주기에 보안활동을통합하는접근입니다. SBOM은 소프트웨어구성 요소와관계를 표현하는목록이며 보안 품질은 기밀성·무결성·가용성등보호 요구를 만족하는제품·운영 특성으로 평가합니다.

• NISTSSDF1.1은 조직준비(PO), 소프트웨어 보호(PS), 안전한 소프트웨어생산(PW), 취약점 대응(RV) 의실무군을제시합니다. 보안 요구·위협 모델·안전 설계·구현 검토·시험·취약점접수/수정·원인 분석을 기존 개발 방법에 통합합니다.

• 자동화는 커밋비밀탐지·SAST, 의존성SCA·라이선스, 컨테이너/IaC설정 검사, DAST/API보안시험, 서명·빌드출처검증, 배포 정책, 운영런타임탐지·패치로연결합니다. 탐지 규칙·심각도·실제도달성·예외 승인·기한·재검증을 관리하지 않으면경보가 쌓이거나배포를 불필요하게막습니다.

• SBOM의이름·버전·공급자·식별자·의존 관계등은 실제 배포물과연결해야합니다. 취약점 목록과 동일한 문서가 아니며새취약점발표시해당구성의영향을 찾는데도움이됩니다. 목록정확성·갱신·서명·취약점 DB·VEX같은적용성정보와 분석을 결합합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
SAST/DAST	소스/실행 행위 분석	오탐·누락·범위
SCA/SBOM	의존위험 분석/구성목록	버전·도달성·갱신
배포·운영 통제	서명·정책·관측	권한·예외·사고복구

적용 예제

새 취약점의 영향 추적

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 공통 라이브러리에 취약점 공개;여러 서비스 배포 가정

1. SBOM으로실제 포함버전과 배포 서비스를 찾습니다.
2. 공격가 능성과업무중요도를평가합니다.
3. 수정 버전 시험·서명·배포를 실행하고 예외는 기한과통제를 기록합니다.
4. 수정 확인과 유사결함의근본원인개선을수행합니다.

결과·해석: 보안 품질을 도구 실행횟수보다위험감소·조치완료·재발방지로검증합니다.

전제·주의: 도구가 모든 보안결함·라이선스위반을찾는것은아닙니다.SBOM형식필드전항은각규격 판본을 확인합니다.

답안 골격과 혼동 방지

보안 품질과 책임 → SSDF4군 → 파이프라인 검사도 식 → SBOM활용예 → 지표·예외

- 스캐너통과를절대안전 인증으로 쓰지않습니다.
- SBOM과 취약점스캔결과를 동일시하지 않습니다.

내용을 가리고 회상

1. 보안자동화에 예외기한이필요한 이유는무엇입니까?
2. SBOM이0-day발표후어떻게도움이됩니까?
3. SSDF의취약점 대응은 개발에 무엇을환류합니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- NIST SP800-218 SSDF1.1 - Murugiah Souppaya;Karen Scarfone;Donna Dodson / NIST; 2022-02; 확인 2026-11-05.
- ScanCode Toolkit Documentation - AboutCode / ScanCode project; 상시문서; 확인 2026-11-05.